

XeFlow DOCUMENTATION

XeFlow 开发与部署手册

架构、环境、权限、接口、数据、测试、发布与运维规范

适用对象	开发人员、测试人员、DevOps、系统管理员、安全审计人员
系统版本	Open-source / main
文档编号	ERP-DEV-2026-01
发布日期	2026-07-27

开源版 | 操作以实际部署版本和账号权限为准

文档说明

本册用途 为系统二次开发、测试、部署、升级、备份、安全审查和故障恢复提供统一技术基线。

项目	内容
系统名称	XeFlow 外贸 ERP
系统版本	Open-source / main
源码基线	Initial public release
文档版本	V1.0
适用环境	本地开发环境、阿里云 ECS 试运营/生产环境
维护原则	界面、权限、业务状态或接口发生变化时同步更新文档与截图

截图说明 截图用于说明页面位置和操作路径。不同角色看到的菜单、按钮和数据范围可能不同；若页面与截图略有差异，请以当前已部署版本和管理员分配的权限为准。

目录与阅读建议

项目概述与技术栈

总体架构

代码结构与分层

本地开发环境

配置与密钥管理

数据库与迁移

认证、RBAC 与数据权限

核心业务状态机

API 与异常规范

文件、模板与定时任务

前端工程规范

测试与验收

Docker/ECS 部署

备份恢复与监控

发布与 Git 工作流

故障排查与安全清单

阅读方式 首次使用建议按顺序阅读；已有经验的用户可直接跳到“按角色操作清单”或具体模块。Word 中可使用“导航窗格”按标题快速定位。

1. 项目概述与技术栈

XeFlow 是前后端分离的外贸业务管理系统，服务客户发展、销售、采购、出货、库存、财务、报表和内部协作。后端持有最终权限与业务规则，前端负责交互、路由和权限提示。

层	技术/组件	职责
前端	Vue 3、TypeScript、Vite、Element Plus	路由、页面、表单、图表、权限可见性
后端	Java、Spring Boot、Spring Security	REST API、认证、业务事务、审计
数据访问	MyBatis-Plus	实体、Mapper、分页与逻辑删除
数据	MySQL 8	业务、RBAC、审计、通知和文档元数据
缓存/会话	Redis 或 memory TokenStore	登录态与多实例共享
文档	Apache POI / Excel 模板 / PDF	PI、PO、SI、出货单和报表导出
部署	Docker Compose、Nginx、阿里云 ECS	容器编排、静态资源、反向代理、HTTPS

2. 总体架构

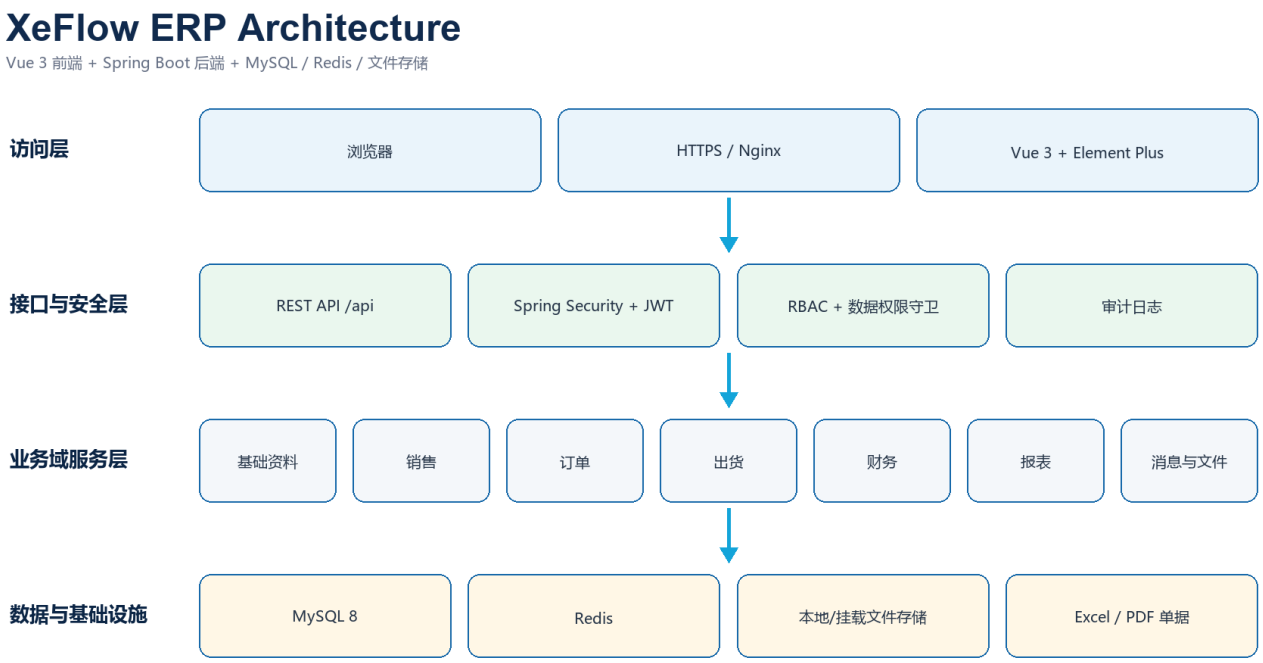


图 1 系统分层与基础设施

所有业务请求经 /api 进入 Spring Security。认证成功后先执行权限码检查，再由数据权限守卫校验记录归属，最后进入领域服务和数据库事务。文件下载还需额外完成路径归一化与根目录校验。

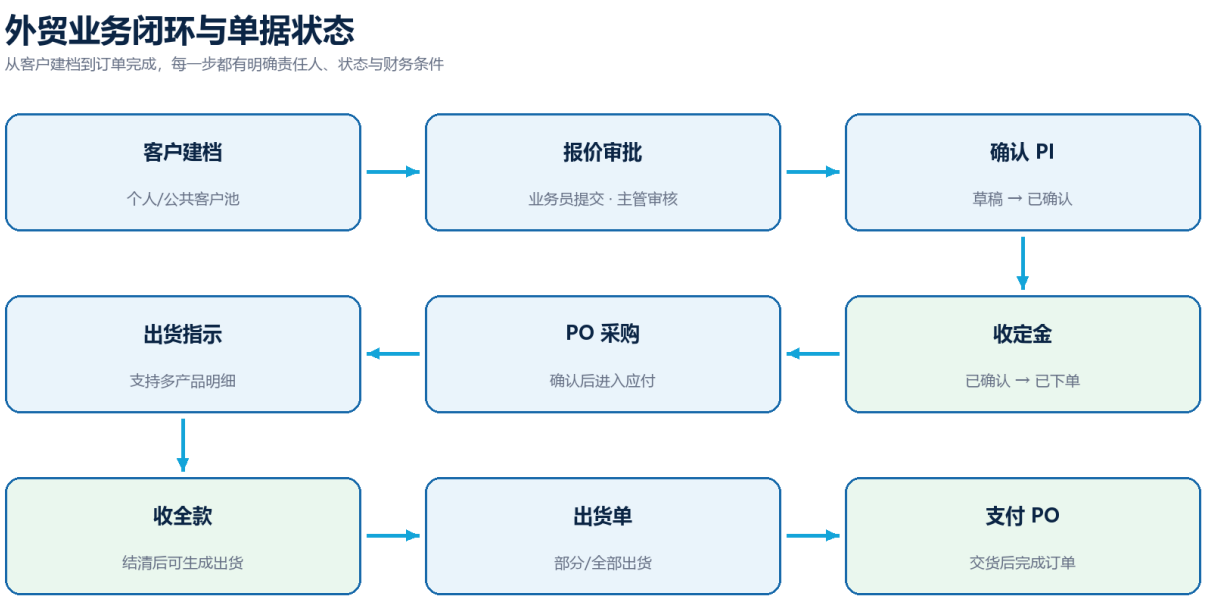


图 2 业务域之间的主单据链路

3. 代码结构与分层

目录/包	用途	约束
erp-frontend/src/views	业务页面	只处理展示和交互，不作为最终权限边界
erp-frontend/src/api	类型化 API 客户端	统一走请求封装，不在页面散写 URL
erp-frontend/src/router	静态路由映射	菜单来自后端，组件路由需保持对应
com.erp.common	响应、异常、安全、审计、文件与文档工具	共享规则放此处前先确认跨域复用价值
com.erp.system	认证、用户、角色、权限、邀请码、审计	超级管理员保护必须在后端实现
com.erp.basedata	客户、产品、BOM、汇率、附件	客户查询使用 customerCode
com.erp.sales	产品报价、销售报价、PI	状态机和 ownerId 数据范围
com.erp.order	OEM、PO、出货指示	关联 PI 及多产品明细一致性
com.erp.shipment	出货单与导出	库存与 PI 出货状态联动
com.erp.finance	流水、应收、应付	原币结算与 CNY 报表转换分离
com.erp.report	采购、销售、利润、业务员业绩	统一统计口径与下钻来源

分层原则 Controller 负责参数、权限注解和响应；Service 负责业务规则、数据范围、事务与状态联动；Mapper 只负责数据访问。

4. 本地开发环境

依赖	建议版本	检查命令
JDK	17+	java -version
Maven	3.9+	mvn -version
Node.js	18/20+	node -v
npm	9+	npm -v
MySQL	8.0	mysql --version
Redis	7（生产推荐）	redis-cli ping
Docker Desktop	当前稳定版	docker version

启动方式

在仓库根目录准备本机 MySQL 数据库和配置。

运行 ./start-dev.ps1 -Store memory 启动后端与前端；调试 Redis 时使用相应参数。

访问 http://localhost:8080/api/actuator/health，确认后端为 UP。

访问 http://localhost:5173，使用测试账号执行冒烟测试。

结束开发时运行 ./stop-dev.ps1，避免端口和旧进程干扰后续测试。

服务	默认地址	用途
前端	http://localhost:5173	开发页面
后端	http://localhost:8080/api	REST API
健康检查	http://localhost:8080/api/actuator/health	进程和依赖健康
Knife4j	http://localhost:8080/api/doc.html	仅开发/授权环境启用

5. 配置与密钥管理

变量	用途	生产要求
MYSQL_*	数据库名、用户和密码	独立低权限账号；不得使用 root 作为应用账号
REDIS_PASSWORD	Redis 认证	随机强密码，端口不暴露公网
ERP_JWT_SECRET	JWT 签名	至少 64 位随机值，定期轮换
ERP_REGISTER_CODE	兼容注册门禁	优先使用数据库邀请码；不得写入仓库
ERP_CORS_ORIGINS	允许前端来源	只允许正式 HTTPS 域名
MAIL_*	SMTP 主机、端口、账号、授权码	授权码作为密钥，不写日志与文档
UPLOAD_ROOT	附件和共享文件目录	挂载持久卷并与数据库一起备份

密钥红线 仓库、Word/PDF、截图、日志、公告和审计记录中不得出现真实密码、SMTP 授权码、JWT secret 或数据库密钥。

6. 数据库与迁移

正式结构由 sql/ 中编号脚本和实体定义共同维护。迁移脚本必须可审查、尽量幂等，并明确是否会锁表、回填数据或改变唯一键。演示数据只放 docs/sample-data，不参与正式初始化。

对象	关键规则
逻辑删除	唯一键设计必须考虑 deleted 字段；删除后重新创建同业务编码不能在二次删除时冲突
客户	对外使用 customerCode；数据库 id 只用于内部关联
PI/PO	主表与明细在同一事务保存；确认、入库、收付款状态联动需幂等
出货指示	主表 + shipping_instruction_item 多明细；历史单行记录需兼容回退
财务	流水保留原币；应收应付结清按原币累计；报表再统一换算 CNY
审计	参数递归脱敏；异常摘要限制长度，避免泄露 SQL/敏感信息

迁移发布步骤

导出数据库与上传文件备份，验证备份可读取。

在测试库执行迁移，记录耗时、警告和影响行数。

运行后端测试、前端构建和关键业务回归。

维护窗口内执行正式迁移和容器升级。

验证表结构、关键数据、健康检查和业务账号。

保留回滚脚本或上一版本镜像，确认稳定后再清理旧资源。

7. 认证、 RBAC 与数据权限

登录返回 JWT，后续请求使用 Authorization: Bearer <token>。权限由用户角色并集形成，后端 @PreAuthorize 和 DataAccessGuard 共同决定是否允许操作。

控制层	作用	禁止做法
菜单权限	决定侧边栏可见模块	不能把隐藏菜单当成唯一安全措施
按钮权限	决定新建、编辑、删除、审核、导出等入口	后端仍需同名权限校验
数据权限	按 ownerId、关联 PI ownerId 或 createBy 限制记录	不能信任前端提交的隐藏数据库 ID
角色策略	最多 3 角色；只读互斥；管理员折叠显示	不能修改其他用户为超级管理员
超级管理员保护	admin 唯一且不可删除、停用、改角色	不能只在前端禁用控件

安全评审点 新增任何详情、导出、下载、附件、修改或删除接口时，都必须复用服务端数据可见性校验。

8. 核心业务状态机

领域	状态/事件	后端约束
PI	DRAFT → CONFIRMED	确认前校验客户、币种和至少一条有效明细；草稿 2 小时清理
PI	CONFIRMED → ORDERED	定金为 0 或登记定金后触发
PI	ORDERED → SHIPPED/COMPLETED	结清全款、库存校验、部分/全部出货联动
PO	DRAFT → CONFIRMED	确认前校验采购明细；确认后进入应付
PO	CONFIRMED → IN_PROGRESS	部分到货入库
PO	IN_PROGRESS → COMPLETED	全部数量入库并登记库存流水
Shipment	PARTIAL / FULL	出货数量不得超过库存和 PI 剩余量
Trace	交货 → 完成订单	全部出货后交货；PO 付款完成后闭环

9. API 与异常规范

本地 API 基址为 http://localhost:8080/api。除登录、注册、验证码和健康检查外，请求通常需要 Bearer Token。

区域	前缀
认证	/auth
客户/产品/BOM/汇率	/basedata/*
报价/PI	/sales/*
OEM/PO/出货指示	/order/*
出货单	/shipment
财务	/finance/*
报表	/report/*
消息/通知/资料共享	/message、/notification、/fileshare
系统管理	/system/*

HTTP 状态	含义	客户端处理
400	参数或业务规则不满足	显示后端明确业务提示，不包装成“系统繁忙”
401	未登录或登录态过期	清理 Token 并跳转登录
403	权限码或数据范围不足	提示无权限；不要自动重试
413	上传超过限制	提示单文件上限和当前文件大小
500	未预期异常	展示通用提示并记录 trace/时间用于排查

用户可理解性 前端错误拦截器应优先显示后端 message；仅在没有业务提示时显示通用错误。

10. 文件、模板与定时任务

能力	实现要求
上传	前后端共同校验大小和后缀；OEM 单文件 50MB；Nginx client_max_body_size 与后端一致
下载	normalize 后确认目标仍位于上传根目录；返回 nosniff 和安全文件名
Excel 模板	以仓库内正式模板为准；插入明细行时复制样式、合并、行高和公式
SI 多产品	从模板第 10 行向下插入，逐条填充产品型号、工厂型号、数量、箱数等
文件共享清理	按 expiresAt 定时删除数据库记录与实际文件，最大有效期 180 天
PI 草稿清理	定时删除超过 2 小时未确认草稿；任务需幂等并记录结果
汇率拉取	每日从中国银行外汇牌价获取中行折算价，失败保留上一有效数据并告警
经营周报	仅发送财务和管理员；标题为“经营周报”；统计统一 CNY

11. 前端工程规范

- 页面遵循现有 Element Plus 表格、弹窗、筛选区和操作列模式，表头和文本默认左对齐。
- 图标统一使用现有图标库：导入、导出、模板下载在所有基础资料模块保持相同语义。
- 动态表单使用稳定 key，数量/金额输入显式处理 0、null 和字符串数字，避免不显示或不可编辑。
- 操作列采用 flex 布局，隐藏状态按钮时不保留占位；剩余操作自动补位并保持单行。
- 长文本使用省略与 tooltip；字段标签禁止把完整中文词拆成两行。
- 所有请求状态具备 loading、防重复提交、成功/失败反馈和关闭弹窗后的重置。

检查	命令
类型检查	cd erp-frontend && npm run type-check
生产构建	cd erp-frontend && npm run build
后端测试	cd erp-backend && mvn test
后端编译	cd erp-backend && mvn -DskipTests compile

12. 测试与验收

测试层	重点
单元/服务测试	状态机、金额、汇率、逻辑删除、唯一键、角色策略、文件路径
接口测试	401/403/413/业务异常、分页、导入导出、上传下载、幂等
权限矩阵	salesman/manager/finance/admin/readonly 对每个模块的读写和数据范围
业务链回归	客户 → 报价 → PI → 定金 → PO → SI 多明细 → 全款 → 出货 → 付款
浏览器验收	1440×900 与常用笔记本宽度；文本不换行错位、弹窗无水平溢出
数据核对	原币结清、CNY 报表、库存入出、单据追踪、通知接收人

最小账号矩阵

账号类型	必须验证
业务员 A/B	A 不能查看或引用 B 的客户、PI、OEM、SI、附件和出货单
销售主管	可看全部销售数据、分配/转移客户、审核报价、按担当查询
财务	可收定金/全款、付 PO、看财务通知；不能审核销售报价
只读	仅查看分配入口，写接口均返回 403
管理员	用户/角色/邀请码/审计和全部业务；不能创建第二个超级管理员

13. Docker / ECS 部署

确认 main 分支目标提交，记录 commit SHA 并完成本地构建。

备份服务器 MySQL、上传目录和当前 .env/Compose 配置。

在 ECS 拉取代码或上传构建产物，检查环境变量未被覆盖。

执行 docker compose up -d --build，观察 backend、frontend、mysql、redis 状态。

检查 /api/actuator/health、登录、菜单、数据库连接与附件卷。

执行关键账号与业务链冒烟，最后清理无引用旧镜像和构建缓存。

组件	生产检查
Nginx	HTTPS、域名、/api 代理、SPA fallback、上传大小、超时和安全响应头
Backend	prod profile、JWT secret、CORS、邮件、数据库/Redis、上传根目录
MySQL	仅内网、字符集 utf8mb4、时区、备份、磁盘余量
Redis	认证、仅内网、持久化策略、重启后登录态预期
Volumes	数据库与附件持久化；容器重建不丢数据
Domain	DNS A 记录、备案、证书自动续期和 HTTP→HTTPS

14. 备份恢复与监控

对象	频率建议	恢复验证
MySQL 全量	每日；重大变更前额外一次	每月至少一次恢复到隔离库并抽查
上传文件	每日增量/定期全量	与数据库元数据同一时间点恢复
配置与证书	每次变更后	确认权限与到期时间
应用日志	按天轮转，保留 14~30 天	可按时间、用户、请求定位
镜像/构建	保留当前和上一稳定版	可在维护窗口内快速回滚

- 监控健康检查、容器重启次数、CPU、内存、磁盘、数据库连接池和 5xx/413 比例。
- 磁盘清理只删除无引用镜像、构建缓存、过期日志和确认可删除的备份；不得直接清理数据库卷。
- 邮件发送失败、汇率拉取失败、定时清理异常应形成日志和管理员告警。

15. 发布与 Git 工作流

从最新 main/trial-v2.0 拉取并确认工作区无未解释修改。

按模块实现，更新数据库迁移、测试、文档和截图。

运行后端测试/编译、前端类型检查/构建和关键回归。

提交信息描述业务结果与风险，不提交 secrets、生产数据和临时文件。

先推送开发/试验分支，验收后安全合并 main。

部署 main 指定 commit，公告应说明影响、修复内容和用户注意事项。

> 可追溯性 部署必须可追溯到明确 commit；服务器上不要长期保留未提交的手工补丁。

16. 故障排查与安全清单

现象	排查顺序
登录失败/系统繁忙	健康检查 → backend 日志 → MySQL/Redis → CORS/代理 → 用户状态/角色
客户删除失败	审计错误 → 关联外键/逻辑删除唯一键 → 数据范围 → 事务回滚
导入失败	模板版本 → content-type/大小 → 表头 → 必填/重复 → 业务权限 → 错误行提示
附件 413	前端 50MB 校验 → Nginx client_max_body_size → Spring multipart 限制
403	权限码 → 用户角色 → Token 是否刷新 → ownerId/PI ownerId/createBy
报表金额异常	原币 → 汇率日期 → CNY 转换 → 筛选/数据范围 → 重复或漏记流水
服务器非最新	git SHA → 镜像构建时间 → Compose 服务镜像 → 浏览器缓存

上线安全清单

- 生产 profile；关闭验证码回传、SQL stdout、公开 API 文档和宽松 CORS。
- JWT、数据库、Redis、SMTP 授权码全部随机化并保存在服务器密钥文件/环境变量。
- admin 使用独立强密码和专用邮箱；日常管理优先使用可删除管理员账号。
- 文件下载路径归一化、nosniff、危险后缀拦截和上传体积限制均已启用。
- 通知 HTML 使用白名单清洗或纯文本；审计参数递归脱敏。
- 备份可恢复、HTTPS 有效、MySQL/Redis 不暴露公网、磁盘余量充足。

附录 A：相关仓库文档

文件	内容
README.md	项目入口与快速启动
docs/architecture.md	架构说明
docs/user-guide.md / modules.md	用户流程与截图索引
docs/development.md	开发规范
docs/deployment.md	部署与备份
docs/security-rbac.md	角色、权限与数据范围
docs/api.md	API 基础规范
docs/troubleshooting.md	常见故障
SECURITY.md	漏洞报告与安全要求